

CISSP Printable Practice Exam 11 - Domain 3 - Security Architecture and Engineering

Practice Exam 02 - Domain 3

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP2-040)

Scenario: An engineering team is designing a remote maintenance service for medical imaging equipment. Its initial diagram lists components but omits trust boundaries, privileged data flows, and attacker entry points.

What should the security architect do NEXT to make the threat model useful for design decisions?

- A. Delay threat analysis until penetration testing begins on the completed service.
- B. Select controls from the prior product release without evaluating the new architecture.
- C. Map assets, data flows, trust boundaries, entry points, and credible threats before selecting mitigations.
- D. Rate every component as equally critical so the same controls apply throughout.

Question 2 (CISSP2-041)

Scenario: A university is automating creation of research collaboration spaces. New spaces currently allow organization-wide discovery and permit external sharing unless the owner changes the settings.

Which provisioning change BEST implements secure defaults?

- A. Keep broad access but send owners monthly reminders to review membership.
- B. Create spaces as private with external sharing disabled, requiring an explicit approved change for broader access.
- C. Allow external sharing by default but record each download for later investigation.
- D. Let each department choose defaults without an organization-wide minimum baseline.

Question 3 (CISSP2-042)

Which formal model is MOST directly concerned with preventing subjects at lower integrity levels from contaminating higher-integrity information?

- A. Bell-LaPadula
- B. Biba
- C. Brewer-Nash
- D. Graham-Denning

Question 4 (CISSP2-043)

Scenario: A logistics company must continue operating a legacy native application while its replacement is developed. Testing shows that memory-corruption defects may permit execution of injected code.

Which architecture-level mitigation provides the BEST immediate defense in depth?

- A. Disable operating-system updates to avoid changing the application's memory layout.
- B. Increase the application's file-storage quota and preserve its current execution privileges.
- C. Use full-disk encryption as the only compensating control for runtime memory defects.
- D. Enable data execution prevention and address-space layout randomization on a supported platform while isolating the application.

Question 5 (CISSP2-044)

Scenario: A transit authority is planning an analytics platform that estimates passenger congestion. The initial design stores precise travel histories tied to persistent rider identifiers even though aggregate patterns meet the stated business need.

Which TWO changes BEST apply privacy by design? Select 2 of the 5 options below.

- A. Collect only the location precision and retention period needed for congestion analysis.
- B. Grant all analysts access to raw travel records to simplify collaboration.
- C. Retain identifiable histories indefinitely in case a future project finds them useful.
- D. Replace direct rider identifiers with controlled pseudonymous values and restrict reidentification capability.
- E. Rely exclusively on a privacy notice while leaving data collection unchanged.

Question 6 (CISSP2-045)

Scenario: A nonprofit adopts a hosted document service. The provider secures the underlying service, but a review finds public-link sharing enabled, dormant privileged accounts, and unrestricted third-party integrations in the tenant.

Which action should the tenant security owner take FIRST?

- A. Ask the provider to replace storage hardware used by the service.
- B. Establish a secure tenant baseline that restricts sharing, privileged access, and integration permissions.
- C. Purchase additional availability capacity before changing access settings.
- D. Move all documents to unmanaged employee devices while the review continues.

Question 7 (CISSP2-046)

Scenario: A hosting environment places hypervisor management interfaces on the same logical segment used by guest workloads. Administrators also browse email from the workstations used to manage hosts.

What is the MOST effective architectural improvement?

- A. Encrypt virtual disks but retain shared management and workload connectivity.
- B. Increase guest virtual-machine memory so workloads are less likely to affect the hosts.
- C. Isolate the management plane, restrict access through dedicated hardened administration paths, and enforce strong privileged controls.
- D. Add endpoint monitoring to administrator workstations without changing management-plane exposure.

Question 8 (CISSP2-047)

Scenario: An insurance platform consists of many independently deployed services. Once a request enters the internal service mesh, downstream services accept the caller's claimed identity and requested operation without performing their own authorization checks.

Which design change BEST limits the impact of one compromised service?

- A. Use longer internal service names to make unauthorized calls more difficult.
- B. Increase the number of service replicas while retaining transitive trust.
- C. Log the first external request and suppress duplicate downstream authorization events.
- D. Require each service to authenticate its caller and authorize the requested resource operation using least privilege.

Question 9 (CISSP2-048)

Scenario: A scientific computing cluster will process projects with different sensitivity levels. Jobs share a scheduler, high-speed interconnect, temporary storage, and compute nodes to maximize utilization.

Which control strategy BEST reduces cross-project exposure without assuming that performance controls alone provide security?

- A. Prioritize sensitive jobs in the queue while using one service identity for all projects.
- B. Increase processor allocation for sensitive jobs but leave shared storage permissions unchanged.
- C. Apply sensitivity-based workload isolation, scheduler authorization, storage separation, and verified cleanup before node reuse.
- D. Rely on researchers to delete temporary files after their jobs complete.

Question 10 (CISSP2-049)

Scenario: A building-automation vendor is redesigning controllers after researchers showed that devices accept unsigned firmware and can be downgraded to vulnerable releases.

Which TWO device capabilities MOST directly address these weaknesses? Select 2 of the 5 options below.

- A. Permit local unsigned installation when network connectivity is unavailable.
- B. Verify a trusted digital signature before installing firmware.
- C. Increase the frequency of device status messages sent to the management console.
- D. Compress firmware packages to reduce update time.
- E. Enforce an authorized version policy that prevents rollback to prohibited releases.

Question 11 (CISSP2-050)

Scenario: A legal services firm must encrypt large case archives for several authorized recipients who do not share a preexisting secret. The design must remain efficient as archive size grows.

Which cryptographic design is MOST appropriate?

- A. Encrypt each archive with a random symmetric data key, then protect that key for each recipient using the recipient's public key.
- B. Hash each archive and treat the hash value as encrypted content.
- C. Encrypt the entire archive separately with each recipient's asymmetric key and omit symmetric encryption.
- D. Use one permanent symmetric key for every recipient and every archive.

Question 12 (CISSP2-051)

Scenario: An internal application validates certificate signatures and expiration dates but never checks whether certificates have been revoked before expiration.

What should the PKI architect add to address this gap?

- A. A larger subject-name field to improve certificate identification
- B. A longer validity period so certificates require less frequent renewal
- C. A defined certificate-status check using current revocation information, with an explicit failure policy
- D. A second copy of each certificate stored beside the application

Question 13 (CISSP2-052)

Scenario: A global manufacturer uses a legacy cryptographic algorithm in applications, embedded equipment, backups, and supplier integrations. The algorithm remains operational but is expected to become unacceptable during the systems' service lives.

What is the BEST initial enterprise response?

- A. Replace only the algorithm name in policy documents while leaving implementations unchanged.
- B. Wait for a practical break before documenting where the algorithm is used.
- C. Increase password complexity in systems that use the algorithm and retain the design.
- D. Inventory cryptographic dependencies and data lifetimes, then create a prioritized migration plan with replaceable algorithms and keys.

Question 14 (CISSP2-053)

Scenario: An analyst studying an obsolete encryption implementation possesses several ciphertexts and the exact original plaintext corresponding to some of them. The analyst uses those pairs to infer information that may help attack other ciphertexts.

Which cryptanalytic attack condition is MOST accurately described?

- A. Ciphertext-only
- B. Known-plaintext
- C. Frequency analysis
- D. Brute force

Question 15 (CISSP2-054)

Scenario: A compliance archive must allow reviewers to detect any alteration to a report and verify which authorized signing identity approved it. Keeping the report content secret is handled separately.

Which operation directly supports the stated integrity and origin-verification requirement?

- A. Generate a report digest and sign it with the approver's protected private key.
- B. Encrypt the report with the approver's public key.
- C. Encrypt the report with the reviewer's private key.
- D. Store an unsigned digest in the same writable repository as the report.

Question 16 (CISSP2-055)

Scenario: A civic records facility is located beside a public street, and its server room wall is close to an employee parking area. The risk assessment identifies unauthorized vehicle approach as a material threat.

Which site-design change BEST addresses the identified threat?

- A. Move visitor parking closer to the wall so personnel can observe arriving vehicles.
- B. Add interior badge readers while retaining unrestricted vehicle access beside the server room.
- C. Install additional server-room cameras without changing the vehicle approach path.
- D. Create adequate standoff distance using rated barriers and route authorized vehicles through controlled access points.

Question 17 (CISSP2-056)

Scenario: A records-processing center experiences brief hot spots and large humidity swings even though the average room temperature appears acceptable. Equipment alarms occur mainly after one cooling unit cycles off.

What is the MOST appropriate corrective design?

- A. Use distributed temperature and humidity sensing with alerting, airflow management, and sufficient redundant conditioning capacity.
- B. Measure temperature only at the room entrance and increase the alarm threshold.
- C. Operate one larger cooling unit without monitoring local environmental variation.
- D. Reduce preventive maintenance so cooling units remain available for production hours.

Question 18 (CISSP2-057)

Scenario: A call center must keep critical computing systems available through short power disturbances and extended utility outages while an orderly shutdown remains possible if backup generation fails.

Which TWO capabilities are MOST important to this design? Select 2 of the 5 options below.

- A. Surge protection that limits voltage spikes but provides no stored energy
- B. A documented load-shedding plan without an alternate power source
- C. An uninterruptible power supply sized to bridge interruptions and support controlled shutdown
- D. A tested backup generator with adequate fuel planning for the required outage duration
- E. Redundant rack power supplies connected to the same unprotected utility circuit

Question 19 (CISSP2-058)

Scenario: A pharmaceutical research facility regularly receives maintenance contractors. Visitors are issued temporary badges at reception but can move unescorted through corridors that lead to laboratories and network rooms.

Which improvement BEST reduces unauthorized visitor movement?

- A. Verify and log visitors, issue time- and area-limited credentials, require appropriate escorts, and recover badges at departure.
- B. Use a different badge color while preserving unrestricted corridor access.
- C. Require contractors to sign a confidentiality agreement as the sole facility control.
- D. Review visitor records quarterly without changing access permissions.

Question 20 (CISSP2-059)

Scenario: A secure operations building is adding a new public training wing. Construction will temporarily open exterior walls, reroute utilities, and place contractors near the existing restricted area.

What should the facility security lead do FIRST?

- A. Transfer all responsibility for restricted-area protection to the construction contractor.
- B. Apply the existing visitor procedure without considering construction-specific access or exposed utilities.
- C. Wait until the training wing opens, then test whether the old perimeter remains effective.
- D. Conduct a change-specific risk assessment and define temporary and permanent boundaries, access routes, monitoring, and utility protections before work begins.

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP2-040) - Correct: C

A useful threat model connects assets and data flows to trust boundaries, entry points, and credible attacker actions, allowing controls to address specific design risks. Reusing prior controls may miss changed threats. Waiting until testing forfeits early design influence, while treating every component identically prevents risk-based prioritization.

Question 2 (CISSP2-041) - Correct: B

A private initial state with external sharing disabled minimizes exposure until an authorized owner deliberately enables additional access. Reminders and logging are useful detective measures but do not prevent unintended disclosure. Departmental flexibility without a minimum baseline can preserve insecure initial configurations.

Question 3 (CISSP2-042) - Correct: B

Biba focuses on preserving information integrity by restricting flows that could allow lower-integrity subjects or objects to corrupt higher-integrity data. Bell-LaPadula protects confidentiality. Brewer-Nash addresses conflicts of interest, while Graham-Denning describes secure creation, deletion, and transfer of access rights.

Question 4 (CISSP2-043) - Correct: D

Data execution prevention impedes execution from nonexecutable memory regions, address-space layout randomization makes target locations less predictable, and isolation limits impact. Storage capacity does not address exploitation. Full-disk encryption protects data at rest, not active memory, and withholding platform updates can leave additional vulnerabilities exposed.

Question 5 (CISSP2-044) - Correct: A, D

Data minimization and limited retention reduce the amount and duration of personal-data exposure, while controlled pseudonymization reduces direct identifiability. Indefinite retention and broad analyst access expand risk. Notice supports transparency but does not substitute for privacy-preserving architecture.

Question 6 (CISSP2-045) - Correct: B

The customer controls tenant configuration, identities, sharing, and permitted integrations, so a secure baseline directly addresses the observed exposure. Provider hardware is outside the tenant's operational role. Additional capacity does not reduce unauthorized access, and unmanaged devices introduce further data-control risk.

Question 7 (CISSP2-046) - Correct: C

Separating the management plane and requiring hardened, tightly controlled administrative paths reduces attack paths to the hypervisor and limits exposure from ordinary workstation activity. More guest memory is unrelated. Disk encryption protects stored data, and endpoint monitoring alone does not remove direct management connectivity.

Question 8 (CISSP2-047) - Correct: D

Independent authentication and resource-level authorization at service boundaries prevent one trusted position from granting unrestricted transitive access. Replication improves availability but preserves the trust flaw. Entry logging cannot enforce downstream permissions, and naming complexity is not an access-control mechanism.

Question 9 (CISSP2-048) - Correct: C

Sensitivity-based isolation, authorized scheduling, separated storage, and verified cleanup

address multiple HPC sharing paths. Processor allocation and queue priority affect performance rather than confidentiality. A common identity removes accountability and least privilege, while voluntary deletion does not reliably sanitize shared resources.

Question 10 (CISSP2-049) - Correct: B, E

Signature verification establishes firmware authenticity and integrity, while anti-rollback enforcement prevents installation of previously valid but now prohibited versions. Status frequency and compression do not establish update trust. An offline exception for unsigned code recreates the unauthorized-installation weakness.

Question 11 (CISSP2-050) - Correct: A

Hybrid encryption uses efficient symmetric cryptography for bulk data and asymmetric cryptography to protect the data key for each recipient. Hashing does not provide confidentiality. Encrypting all bulk content asymmetrically is inefficient, while one permanent shared key creates excessive exposure and difficult revocation.

Question 12 (CISSP2-051) - Correct: C

Relying applications must consult current revocation status, such as an appropriate certificate revocation list or online status service, and handle unavailable status according to documented risk requirements. Longer validity increases exposure after compromise. Subject-name size and duplicate certificate storage do not reveal revocation.

Question 13 (CISSP2-052) - Correct: D

An inventory tied to data and system lifetimes reveals exposure and enables prioritized migration toward crypto-agile implementations. Waiting for exploitation eliminates planning time. Password changes do not strengthen a deprecated algorithm, and policy wording without implementation change provides no technical protection.

Question 14 (CISSP2-053) - Correct: B

A known-plaintext attack uses available plaintext and its matching ciphertext to learn about the cipher or key. A ciphertext-only attack lacks corresponding plaintext. Frequency analysis relies on statistical patterns, while brute force systematically searches the key space rather than depending on known pairs.

Question 15 (CISSP2-054) - Correct: A

Signing the digest with the approver's protected private key lets reviewers use the corresponding public key to verify integrity and origin. Encryption with the approver's public key is aimed at confidentiality for that approver. Private-key encryption is not an appropriate confidentiality design, and a colocated unsigned digest can be altered with the report.

Question 16 (CISSP2-055) - Correct: D

Standoff distance, appropriately rated barriers, and controlled vehicle entry directly reduce the opportunity and impact of unauthorized vehicle approach. Interior badges govern people after entry. Cameras add detection but do not stop a vehicle, and moving parking closer increases rather than reduces proximity risk.

Question 17 (CISSP2-056) - Correct: A

Distributed sensing detects local conditions, airflow management addresses hot spots, and redundant capacity avoids dependence on one cooling unit. An entrance sensor can conceal rack-level extremes. One larger unit creates a concentration of failure risk, while reduced maintenance makes environmental failure more likely.

Question 18 (CISSP2-057) - Correct: C, D

A properly sized uninterruptible power supply provides immediate conditioned power and shutdown time, while a tested generator supplies longer-duration backup with appropriate fuel support. Surge protection does not provide energy during an outage. Load shedding without alternate power cannot sustain service, and redundant supplies on one unprotected circuit retain a common power dependency.

Question 19 (CISSP2-058) - Correct: A

Verified registration, constrained credentials, escorting, and badge recovery create preventive and accountable visitor controls matched to sensitive zones. Badge color improves visibility but not enforcement. An agreement is administrative rather than a physical barrier, and retrospective record review does not prevent unauthorized movement.

Question 20 (CISSP2-059) - Correct: D

Construction changes physical boundaries, traffic patterns, and utility exposure, so risks and compensating controls must be assessed before work starts. The ordinary visitor procedure may not cover these conditions. Post-construction testing is too late to protect the work period, and organizational accountability cannot be fully transferred to a contractor.